

Cruscotto HR — Domande tecniche per il Cliente / Referente tecnico

Preparato da: Perfexia Srl **Progetto:** Cruscotto HR (ecosistema GRU / DFP) **Oggetto:** Chiarimenti tecnici necessari per procedere con autenticazione (Keycloak), segregazione dei dati per ruolo e pannello di amministrazione. **Legenda priorità:** ● Bloccante · ● Alta · ● Media · ● Bassa

Premessa — contesto tecnico (per inquadrare le domande)

Dall'analisi del codice e dello schema dati emerge il quadro seguente:

- L'applicazione adotta già un modello **multi-tenant a separazione logica** (un'unica base dati Supabase, con i dati filtrati per tenant). Oggi il tenant è l'**ente**: lo scoping avviene esclusivamente per `id_ente`.
- Sono presenti a schema le entità relative al **comune** (`lh_comune` , `lh_sede_ente` che collega **ente** ↔ **comune**, `lh_utente.id_comune_sede_lavoro`), ma **non** sono usate per filtrare i dati analitici (`dw_*`).
- I ruoli attualmente implementati (in versione dimostrativa) sono **due**:
 - `dfp` → amministratore globale, vede tutto (nessun filtro);
 - `ente_hr` → vede solo il proprio ente (filtro `id_ente`).

Il modello a **3 ruoli** richiesto (super amministratore / responsabile ente / responsabile comune) corrisponde al modello standard della PA (profilo *sovracomunale* = Ente capofila/Unione; profilo *comunale* = singolo Comune). La sua realizzazione dipende dalle risposte alle domande della sezione A.

● A. Semantica "ente/comune" e segregazione dei dati

Punto centrale: definisce se il terzo ruolo ("responsabile comune") è un semplice rinominamento dell'attuale scoping o richiede un intervento sui dati.

1. Cosa rappresenta un "ente" nel contesto GRU/DFP?
 - a) un **singolo Comune** (corrispondenza 1:1 ente = comune), oppure
 - b) un'**Unione / Ente capofila** che aggrega **più Comuni** (relazione via `lh_sede_ente`)?
2. Le tabelle **analitiche** (`dw_*` e future `ca_*`) sono/saranno filtrabili per **comune** (colonna `id_comune`), o la chiave minima resta `id_ente` ?
3. Il "**responsabile comune**" deve vedere **solo il proprio comune** anche quando questo fa parte di un ente più grande? (Se sì e le `dw_*` non espongono `id_comune` , è necessario un intervento sul modello dati/ETL.)
4. Un responsabile (ente o comune) può vedere **benchmark aggregati e anonimi** degli altri perimetri, oppure **nessun dato** al di fuori del proprio?
5. Il **super amministratore** vede tutti i dati **in chiaro**, o sono previste viste con **anonimizzazione**?

● B. Conformità GDPR e livello di enforcement della segregazione

La segregazione dei dati è un obbligo di legge (principio di **minimizzazione**), non solo una scelta di UI. Va deciso **dove** viene imposta.

6. Si conferma l'adozione della **Row-Level Security (RLS)** di Supabase per imporre la segregazione **a livello di database** (in base ai claim del token), invece del solo filtro applicativo attuale? (*È la modalità corretta per garantire la minimizzazione GDPR a livello infrastrutturale: l'utente non può tecnicamente accedere a dati fuori perimetro, nemmeno manipolando le richieste.*)
7. Esistono **vincoli/policy privacy** specifici (es. dati particolari, mascheramento di determinati campi, log del consenso) da recepire nelle policy di accesso?
8. **Retention** richiesta per i log di sicurezza, accesso e consenso privacy?

C. Keycloak / identità / claim del token

Mappatura naturale: **super admin** → **dfp**, **responsabile ente** → **ente_hr**; il terzo ruolo (comune) è nuovo.

9. Il **JWT** emesso da Keycloak conterrà i claim necessari allo scoping: **ruolo**, **ente_id** e (se serve il livello comunale) **id_comune** dell'utente?
10. Come si chiamano **esattamente ruoli e claim** nel realm, per mapparli ai nostri 3 ruoli?
11. Dove risiede l'associazione **utente** → **ente/comune**: in Keycloak, nel **Portale GRU**, o in una tabella su Supabase?
12. **URL del realm**, **client-id** e **flusso** previsto (Authorization Code + PKCE?) — appena disponibili.
13. Come si integra il JWT di Keycloak con **Supabase** (JWT esterno / RLS basata sui claim)? È già predisposto lato Portale GRU?

D. Pannello di amministrazione

14. I **log** (errori/eventi/accessi/sicurezza/consenso privacy) vanno scritti da **noi** su Supabase, o esiste un **sistema di logging centralizzato GRU** a cui agganciarci?
15. Le **tabelle base** (comuni/province/regioni/nazioni) hanno una **fonte ufficiale** (ISTAT/MEF) già gestita altrove, o dobbiamo prevederne il CRUD nell'admin? (*A schema esistono già **lh_comune** e affini.*)
16. La **gestione ruoli** è fissa sui 3 ruoli o serve una gestione **dinamica** (ruoli/permessi personalizzabili)?
17. Le **statistiche di utilizzo** delle funzionalità (per evidenziare le funzioni inutilizzate) vanno raccolte da noi via event-logging, o esiste già una fonte?

E. Percorsi guidati (User Journey)

18. Si conferma che **solo il percorso D3 (8 passi)** è validato dagli esperti tematici? Gli altri li marchiamo come **"bozza / da validare"** in attesa di conferma Formez/DFP?
19. La funzione "il DFP crea **percorsi personalizzati**" è **in scope adesso** o rimandata alla coprogettazione? (*La nostra struttura è già data-driven: i percorsi sono configurabili.*)

F. Ecosistema dati e alimentazione

20. Le **4 rilevazioni KPI** sono definitive: lo schema **dw_*** è da considerarsi **stabile**?
21. **Syllabus/inPA**: esito della verifica sulla disponibilità di **statistiche scaricabili**? In assenza, quale **struttura minima di dati sintetici** è accettabile?
22. **Conti Annuali (ca_*)**: **data prevista** di popolamento via Talaxy/Talend? (*È il trigger per passare da **dw_*** a **ca_*** e rimuovere i badge "dato dimostrativo".*)
23. Le **correzioni manuali via Excel** (anomalie storiche dei dati dei comuni) devono passare da una **vista admin di override**, o restano un processo esterno da presidiare?

G. Ambiente e deploy

24. Deploy su **Azure**: quale servizio (App Service / Container / Static Web App)?
25. La **Supabase di produzione** sarà **cloud gestita** o **self-hosted su Azure**? (*Impatta URL, gestione del JWT e configurazione RLS.*)
-

Riepilogo dei punti bloccanti

Prima di sviluppare **autenticazione + segregazione per ruolo** è indispensabile chiarire:

- **A1** — semantica "ente" (singolo Comune vs Unione/capofila);
- **A2/A3** — granularità dei dati (`id_ente` vs `id_comune`);
- **B6** — enforcement della segregazione via **RLS** (conformità GDPR);
- **C9** — claim disponibili nel token Keycloak (ruolo / ente_id / id_comune).

Le altre domande possono essere affinate progressivamente in coprogettazione senza bloccare l'avvio dello sviluppo.

Documento predisposto per la condivisione con il referente tecnico del Cliente.